

FIAP

Turma 1AIE

NABBA

AI Engineering & Multi-Agents

Governance & Responsible AI

Parte 3 ✓

 /sergiomantovani

@ /profsergio.mantovani@fiap.com.br

Quem sou eu?



Sergio Mantovani

- 48 anos, casado, pai de uma menina de 13 anos

Hobbies principais:



Resumo profissional:

- Diretor associado de AI & Data na Accenture, líder da prática de “Responsible AI” para América Latina
- +25 anos de experiência, focado em soluções de Dados e IA, e passagens por empresas multinacionais de diversos ramos, como bens de consumo, farmacêutico, telecom, seguros e financeiro, recursos naturais, tendo exercido papéis de liderança regional América Latina e Global.
- Graduado em Análise de Sistemas, e pós-graduado em Administração e em Gestão de Projetos, além de diversos cursos e certificações técnicas e de gestão, incluindo “Responsible AI” na Universidade de Stanford/USA.
- Coautor do “Guia de IA para Conselheiros de Administração” lançado em Out/2024 (Accenture, Microsoft e IBGC).
- Professor no MBA de Data Science & IA e no MBA AI Engineering & Multi-Agents da FIAP

Contatos:



/sergiomantovani



@profsergio.mantovani@fiap.com.br

Principais empresas:

accenture

Porto

BUNGE

Mondelēz
International

Roche

natura

Expertise:

- Responsible AI
- Data & AI Strategy
- Data & AI Governance
- Data Architecture
- Data Engineering
- Data Analytics
- Project Mngmt & Agile Methods

Agenda de Aulas

Turma: 1AIE

Junho 2026						
D	S	T	Q	Q	S	S
	1	2	3	4	5	6
7	8	9	10	11	12	13
14	15	16	17	18	19	20
21	22	23	24	25	26	27
28	29	30				

Julho 2026						
D	S	T	Q	Q	S	S
			1	2	3	4
5	6	7	8	9	10	11
12	13	14	15	16	17	18
19	20	21	22	23	24	25
26	27	28	29	30	31	

Agenda da disciplina

Temas das 5 aulas - Turma 1AIE

Temas que vamos cobrir

1	Governança e Gestão de Dados
2	Riscos da IA e Princípios de IA Responsável
3	Governança, Frameworks e Regulação
4	Mitigação de Riscos da IA
5	Considerações para Agentic AI e Projeto Final

O PAPEL DO AI ENGINEER

Você não é só técnico.

Você é responsável por:

Decisões automatizadas

que afetam pessoas reais

Impacto em pessoas

clientes, funcionários, sociedade

Risco organizacional

regulatório, financeiro, reputacional

Considerações Importantes

- Procure ser pontual – As aulas iniciam-se às 19h e terminam às 23h
 - Chamadas são liberadas às 19:15h e 22:40h
- Se possível, silencie seu celular e os demais canais de comunicação. Desconecte-se!
- Será ótimo se você puder ligar sua câmera!!
- Participe das aulas
 - Pergunte. Este é o momento!
 - Compartilhe exemplos da sua experiência profissional, pessoal ou de algo que você leu
 - Traga novos assuntos ligados à disciplina
 - Seu feedback é precioso
- Faça as atividades sugeridas em sala de aula
- Apesar de virtual, sua participação deve ser real

Onde estamos na disciplina

5 partes, perspectivas complementares

01

Governança & Gestão de Dados

DAMA, qualidade, ciclo de vida, metadados, produto de dados

02

Riscos da IA & Princípios de IA Responsável

Taxonomia de riscos · princípios de IA Responsável · Estudo de Casos

03

Governança, Frameworks e Regulação

Melhores Práticas em Governança de IA · NIST AI RMF · ISO 42001 · EU AI Act · LGPD · PL 2338

04

Mitigação de Riscos da IA

Justiça · robustez · XAI · privacidade · segurança · guardrails

05

Agentic AI & Projeto Final

Agentes autônomos, riscos amplificados · Quantum Commerce

VOCÊ ESTÁ AQUI

GOVERNANCE & RESPONSIBLE AI

Governança, Frameworks e Regulação

Governança de IA – Visão Geral



01

Estruturas, Papéis & Responsabilidades

Patrocínio executivo, comitê de governança, CoE de IA, papéis (CRAO/CGAO) e políticas



02

Gestão de Riscos da IA

Identificação, análise e controles para riscos de dados, modelo, operacionais e éticos



03

Frameworks e Regulamentações

ISO 42001, NIST AI RMF, EU AI Act, PL 2338/2023 e normas setoriais (ex.: CFM)



04

Gestão de Valor da IA

Inventário de casos de uso, ROI, FinOps, AI Literacy e medição de maturidade

01 Estruturas, Papéis & Responsabilidades

Governança de IA em prática



Patrocínio Executivo (Sponsorship)

Por que o patrocínio executivo é essencial?

A governança de IA não é responsabilidade apenas do time técnico. Ela requer autoridade formal, alocação de orçamento e alinhamento estratégico que só a liderança sênior pode garantir.

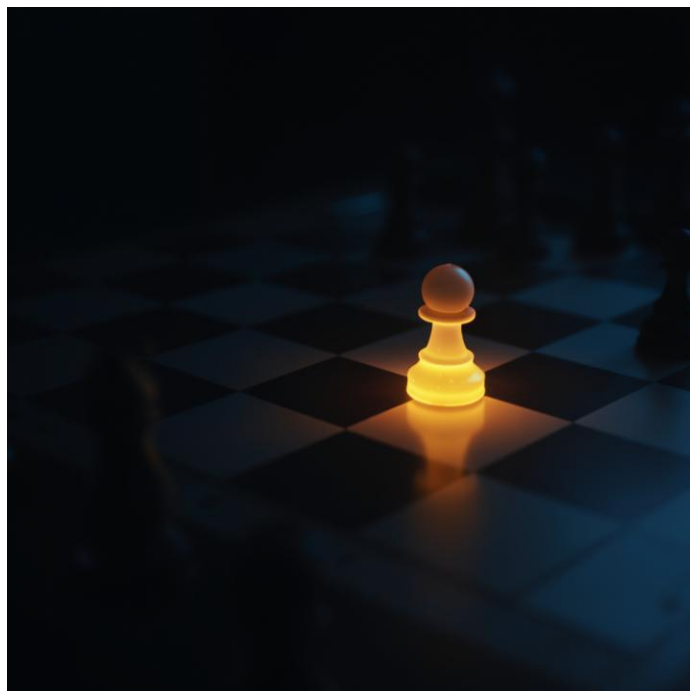
Algumas empresas criam o papel de **Chief Responsible AI Officer (CRAO)** ou **Chief Governance AI Officer (CGAO)**, figuras permanentes que lideram a agenda de IA responsável.

Responsabilidades do Sponsor Executivo

- ✓ Definir e aprovar visão estratégica e princípios de IA
- ✓ Garantir representação multifuncional na governança
- ✓ Solicitar e gerir o orçamento de IA
- ✓ Aprovar políticas e casos de uso de alto risco
- ✓ Responsabilizar-se pelos riscos em última instância
- ✓ Reportar ao conselho de administração

Apenas 52% das empresas têm programa de IA responsável em vigor (BCG, 2025). Mesmo nas que possuem, 79% são de pequena escala e 70% carecem de controles e supervisão adequados. O gap entre discurso e prática é enorme.

Definição da Estratégia de IA



01

Problemas de Negócio

Identifique problemas reais do setor ou da empresa. Foco em eficiência, receita e mitigação de riscos, não em modismo.

02

Priorização de Oportunidades

Colete iniciativas das áreas e una pilotos fragmentados numa estrutura coerente.

03

Roadmap: Pessoas, Processos, Tech

Plano de 90 dias a 12 meses, CoE, ferramentas, contratações e upskilling.

04

Verba e Alinhamentos

Financiamento aprovado, conselho de supervisão e política de uso com o jurídico.

Pergunta-chave: Se você fosse apresentar uma estratégia de IA ao board amanhã, qual problema de negócio seria o ponto de partida?

Áreas responsáveis pela Governança de IA

Business functions assigned primary responsibility for AI governance, 2024 vs. 2025

Source: McKinsey & Company Survey, 2025 | Chart: 2026 AI Index report

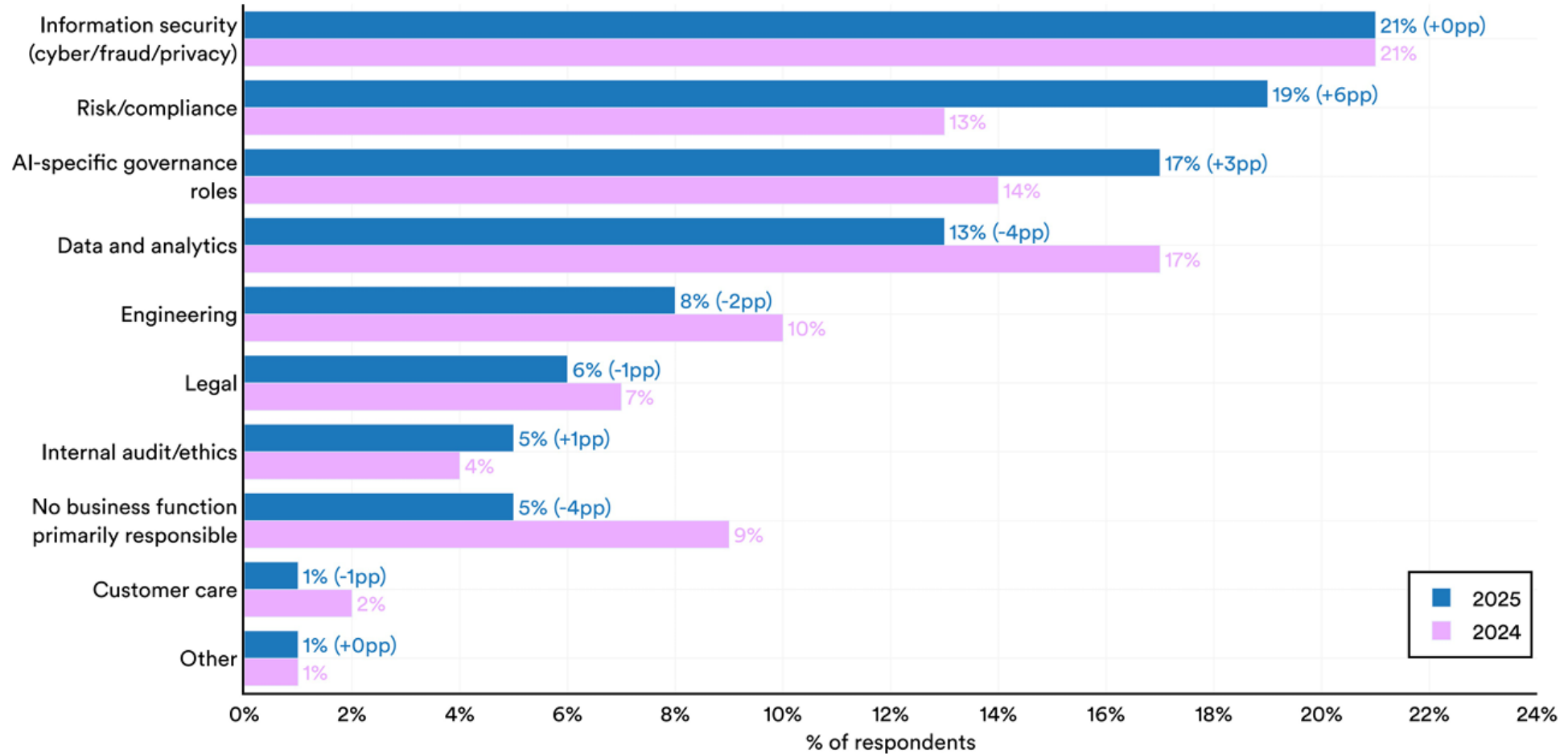
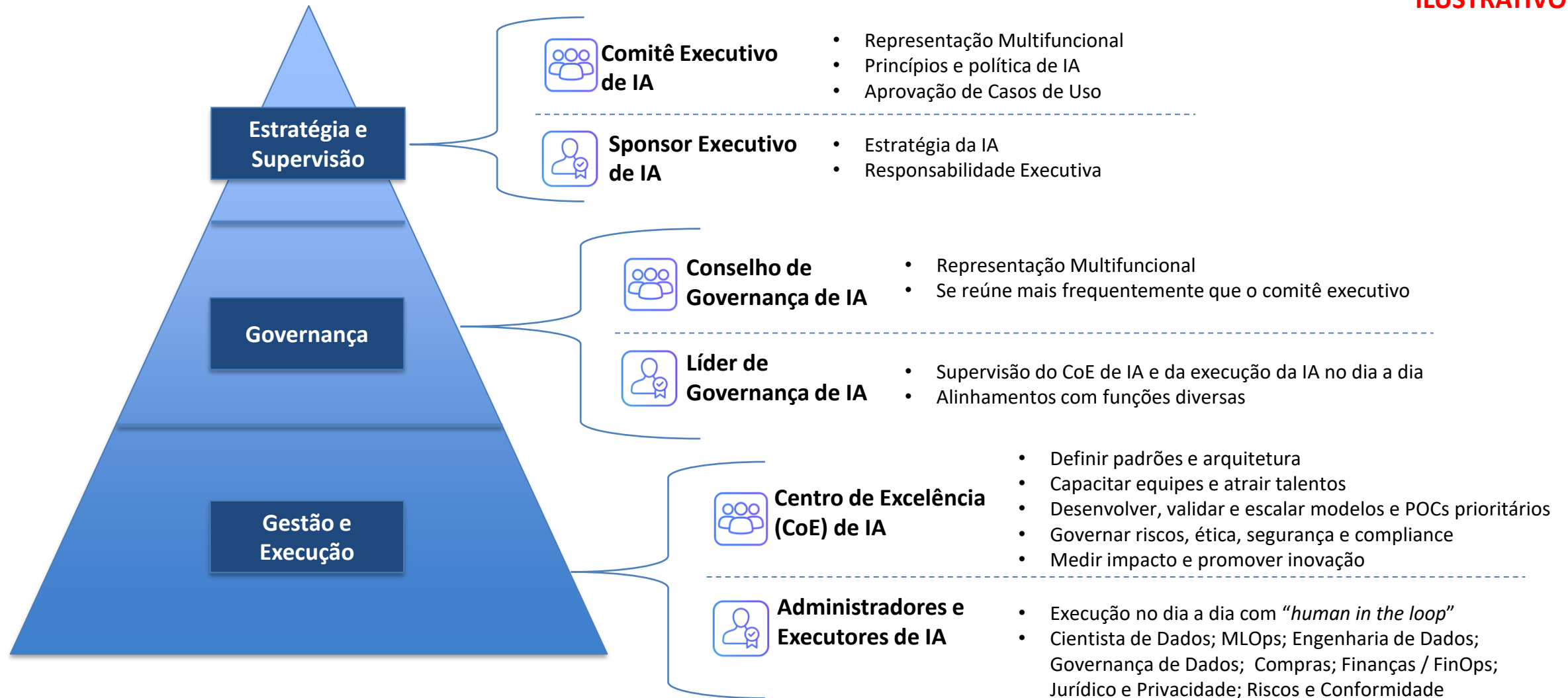


Figure 3.3.6⁷

Estruturas de Governança de IA

**EXEMPLO
ILUSTRATIVO**



AI Center of Excellence (CoE)

- Um COE é um centro de conhecimento físico ou virtual que concentra expertise e recursos existentes em uma disciplina ou capacidade para atingir e sustentar desempenho e valor de classe mundial.
- Ao organizar a IA, deve-se encontrar um **equilíbrio entre o desenvolvimento e o uso da IA pelas unidades de negócios, versus a governança e a orquestração centralizada da IA.**
- As responsabilidades do COE de IA incluem múltiplas funções que serão exercidas por diferentes partes da organização:

Governança de IA

Avaliações de impacto · Registro de modelos

Jurídico, Privacidade e Conformidade

Órgãos reguladores · Mudanças regulatórias

Gestão de Riscos

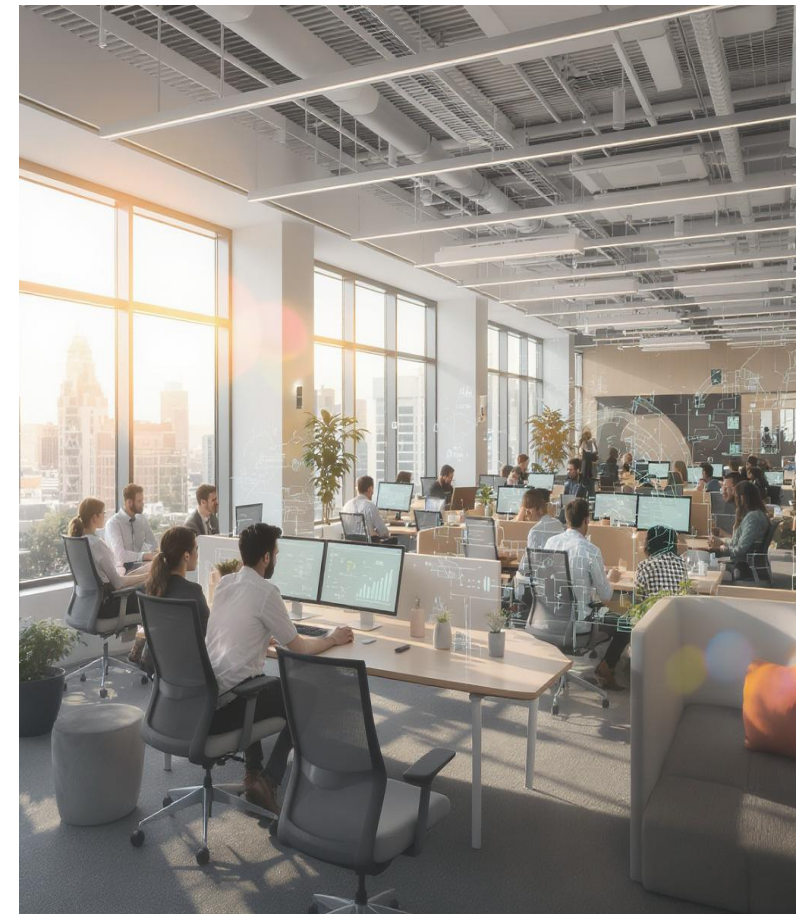
Inventário PRCI para IA · Métricas de risco

Finanças & FinOps

Custo de IA por modelo/área · ROI das iniciativas

Tecnologia & Segurança

Padrões de arquitetura · Capacitação · DLP para IA



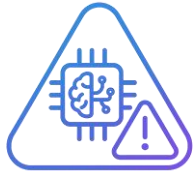


02

Gestão de Riscos da IA

Identificar · Avaliar · Mitigar · Monitorar

Gestão de Riscos da IA



Risco de IA = (as chances de um sistema de IA ser explorado ou gerar um resultado incorreto) x (as consequências do erro ou da exploração)

**Baixa Probabilidade
Alto Impacto**

Risco ALTO
Avaliação formal necessária

**Alta Probabilidade
Alto Impacto**

Risco INACEITÁVEL
Ação imediata obrigatória

**Baixa Probabilidade
Baixo Impacto**

Risco MÍNIMO
Código de conduta voluntário

**Alta Probabilidade
Baixo Impacto**

Risco LIMITADO
Transparência requerida

Categorias de Riscos da IA

1 Riscos de Dados

- Segurança e acesso não autorizado aos dados de treino
- Privacidade e uso indevido de dados pessoais/sensíveis
- Integridade: dados enviesados ou incompletos corrompem o modelo
- Exposição de dados confidenciais via outputs (memorização)

2 Riscos de Modelo

- Ataques adversariais: entradas manipuladas enganam o modelo
- Prompt injection e jailbreak em modelos generativos (LLMs)
- Ataques à cadeia de suprimentos (bibliotecas, pipelines, APIs)
- Viés algorítmico e tomada de decisão discriminatória

3 Riscos Operacionais

- Data drift: modelo desatualizado em relação à realidade atual
- Falta de escalabilidade e plano de suporte pós-deploy
- Integração inadequada com sistemas e processos legados
- Accountability gap: roles e responsabilidades não definidos

4 Riscos Éticos e Legais

- Violações de LGPD, GDPR, CCPA e EU AI Act
- Discriminação sistemática de grupos protegidos
- Exposição de propriedade intelectual e segredos comerciais
- Responsabilidade civil por danos causados por decisões de IA

Abordagem Baseada em Risco (EU AI Act)



Quanto maior o risco, maiores as obrigações de conformidade.

Risco INACEITÁVEL
Sistemas proibidos

*Manipulação subliminar · Reconhecimento facial em massa ·
Score social*

Risco ALTO
Avaliação formal obrigatória

Saúde · Crédito · Emprego · Infraestrutura · Justiça

Risco LIMITADO
Transparência requerida

Chatbots que se identificam como IA · Deepfakes com aviso

Risco MÍNIMO
Código de conduta voluntário

Filtros de spam · Recomendações · Jogos com IA

Avaliação de Riscos de IA: Passo a Passo

#	Etapa	O que envolve / Inputs	Entregáveis (exemplos)
1	Contexto & Governança	Escopo do sistema · Partes interessadas · Appetite de risco da organização	Política de Risco de IA · RACI de papéis
2	Identificação de Riscos	Revisão técnica do modelo · Entrevistas com usuários · Análise de dados de treino	Registro de riscos (risk log)
3	Análise & Priorização	Matriz probabilidade × severidade · Avaliação de grupos impactados	Matriz de riscos priorizada
4	Tratamento & Controles	Controles técnicos (ex.: testes adversariais, SHAP, fairness metrics) · Controles organizacionais (ex.: revisão humana)	Plano de ação e KPIs de risco
5	Monitoramento & Aprendizado	Monitoramento de drift · KPIs de fairness em produção · Gestão de incidentes	Relatórios contínuos e lições aprendidas

Exemplo: Avaliação de Riscos em Concessão de Crédito

Contexto: banco que usa modelo de ML para aprovação automática de crédito pessoal
(100 mil decisões/mês)

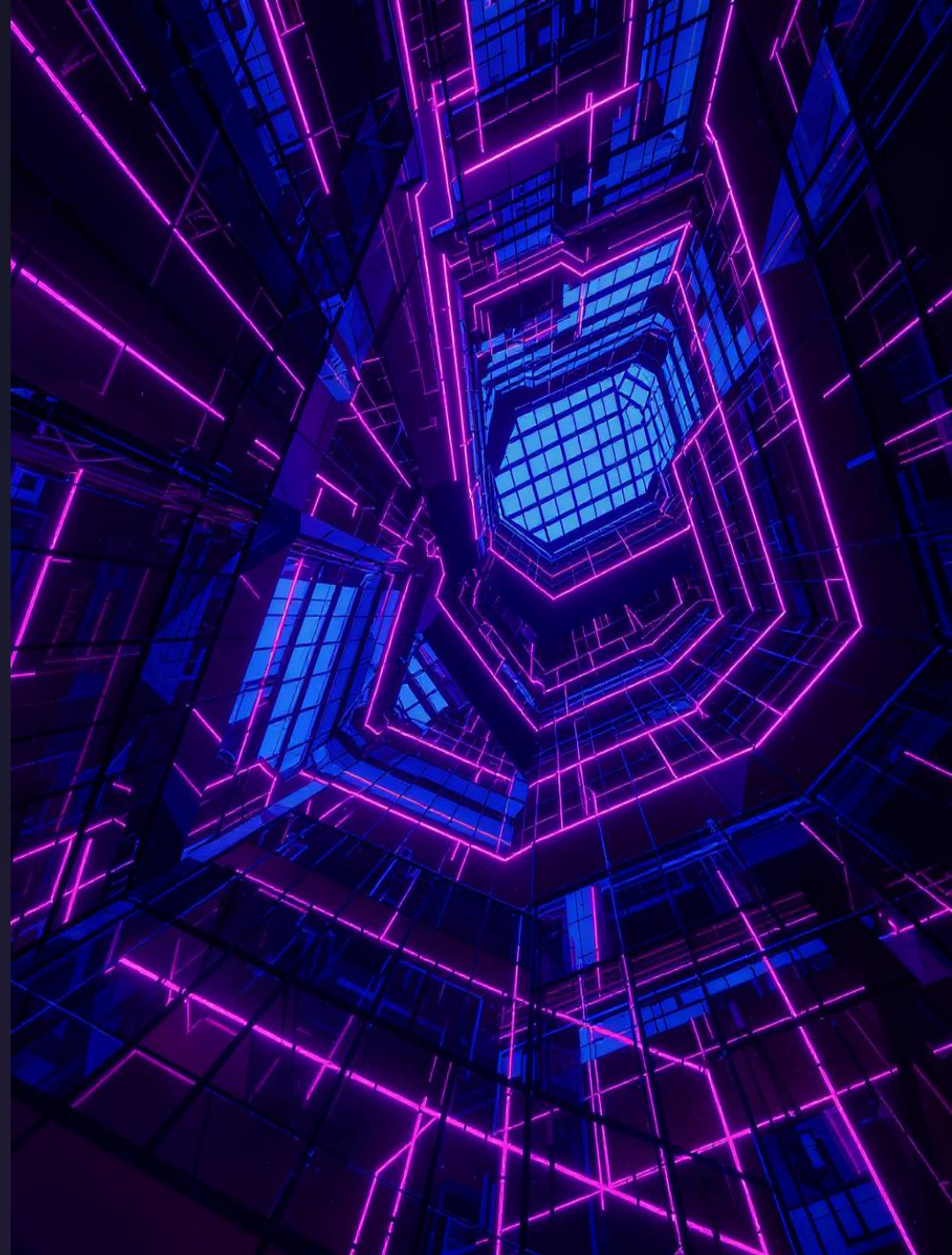


Risco Identificado	Impacto	Prob.	Nível	Controle / Mitigação
Dados históricos com viés de gênero/raça	Alto	Alta	ALTO	Auditoria de fairness (SHAP, AIF360); re-balancear dataset; monitorar métricas de equidade por grupo
Memorização de CPF/dados pessoais sensíveis	Alto	Média	ALTO	Anonimização no pipeline de treino; testes de extração de dados; DPO oversight
Decisões não explicáveis para clientes negados	Médio	Alta	ALTO	Implementar LIME/SHAP para explicações individuais; processo de contestação humana
Data drift (perfil econômico muda pós-recessão)	Médio	Média	MÉDIO	Monitoramento contínuo de distribuição de features; re-treino periódico com aprovação
Prompt injection via interface de atendimento	Baixo	Alta	MÉDIO	Sanitização de inputs; guardrails de output; testes de red team trimestrais

03

Frameworks e Regulamentações de IA

ISO · NIST · EU AI Act · PL 2338 · CFM



Normas ISO para Inteligência Artificial

A ISO/IEC JTC 1/SC 42 publica normas que estruturam o desenvolvimento e uso responsável de IA.

ISO/IEC 42001:2023 AI Management Systems

Especifica requisitos para estabelecer, implementar, manter e melhorar continuamente um Sistema de Gestão de IA (AIMS). Certificável.

ISO/IEC 23894:2023 AI Risk Management

Orientação sobre como organizações que desenvolvem, produzem ou usam IA podem gerenciar riscos específicos, integrando-os às funções de gestão.

ISO/IEC 24368:2022 Ethical & Societal Concerns

Visão geral de alto nível de preocupações éticas e sociais da IA. Voltado a tecnólogos, reguladores e sociedade. Não prescreve valores.

ISO/IEC 42005:2025 AI Systems Impact Assessment

Orienta como planejar, executar e documentar Avaliações de Impacto de Sistemas de IA (AI-IA) sobre indivíduos, grupos e a sociedade.



ISO/IEC 42001:2023 - AI Management Systems



O QUE É?

A ISO 42001:2023 fornece um framework para organizações de qualquer porte e setor gerenciarem os riscos e oportunidades associados à IA, promovendo o uso ético, transparente e confiável dessa tecnologia.



PARA QUE SERVE?

- ✓ Gerenciar riscos e oportunidades da IA de forma sistemática e proporcional.
- ✓ Aumentar a confiança das partes interessadas no uso de IA.
- ✓ Atender a requisitos legais e regulatórios aplicáveis.
- ✓ Promover melhoria contínua nos sistemas e práticas de IA.
- ✓ Gerar valor de negócio com responsabilidade.



PRINCÍPIOS FUNDAMENTAIS



ÉTICA E TRANSPARÊNCIA

Promover decisões justas, imparciais e explicáveis.



RESPONSABILIDADE

Definir papéis e garantir prestação de contas ao longo do ciclo de vida da IA.



SEGURANÇA E PRIVACIDADE

Proteger dados, sistemas e pessoas contra usos indevidos e riscos.



INCLUSÃO E NÃO DISCRIMINAÇÃO

Evitar vieses e promover acessibilidade e equidade.



CONFIABILIDADE

Buscar desempenho consistente, robusto e alinhado aos objetivos.



PARA QUEM É?

Aplicável a qualquer organização que desenvolva, forneça, utilize ou seja impactada por sistemas de IA.



Empresas privadas



Órgãos públicos



Instituições acadêmicas



Startups e fornecedores de IA



ESCOPO ABRANGENTE

Aplica-se a todo o ciclo de vida dos sistemas de IA: planejamento, desenvolvimento, implantação, operação, monitoramento e desativação.

ESTRUTURA DA NORMA

A ISO 42001 segue a abordagem de alto nível (HLS) e o ciclo PDCA.



REQUISITOS-CHAVE DA NORMA



Contexto da organização



Liderança e comprometimento



Planejamento



Suporte (recursos, competência, conscientização, comunicação e informação)



Operação



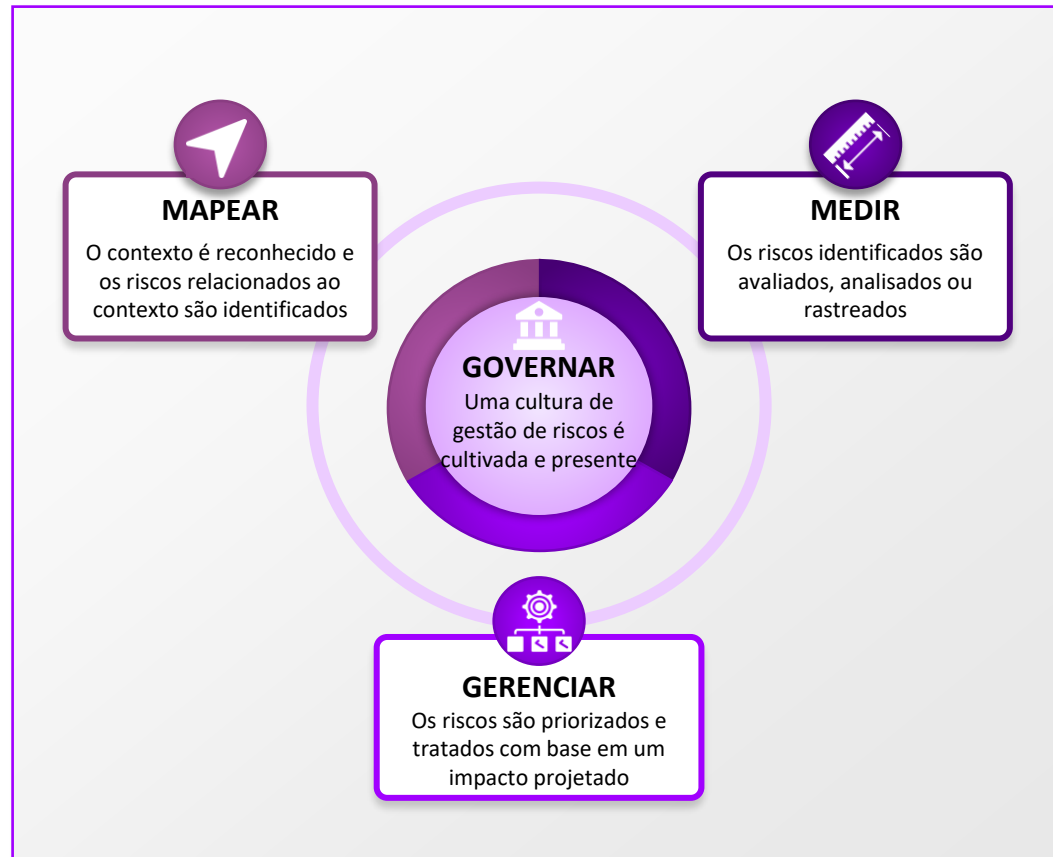
Avaliação de desempenho



Melhoria

NIST AI RMF (Risk Management Framework)

Fonte: https://airc.nist.gov/RMF_Overview



Princípios / Características

VÁLIDO E CONFIÁVEL

Fornecer **evidências objetivas** do cumprimento dos requisitos gerais **garante a correção** das operações do sistema de IA, sem falhas, durante toda a sua vida útil.

SEGURO

Os sistemas de IA **não devem ser uma fonte de danos para os seres humanos**, para a sua saúde e propriedade, ou para o ambiente, levando a **abordagens adaptadas** com base no contexto e nos riscos

SEGURO E RESILIENTE

Os sistemas de IA devem retornar à função normal após **eventos inesperados** e ser robustos (proteger ou reagir) contra o **uso adversário** do modelo ou de seus dados

EXPLICÁVEL E INTERPRETÁVEL

Os sistemas de IA devem oferecer informações que ajudem os utilizadores finais a **obter mais informações**, compreendendo assim os **propósitos, os resultados e o impacto potencial** de um sistema de IA

PRIVACIDADE MELHORADA

Os sistemas de IA devem ser dotados de **tecnologias de melhoria da privacidade (PETs)**, ou seja, métodos de minimização de dados para ajudar a salvaguardar a autonomia, a identidade e a dignidade humanas.

JUSTO – COM PRECONCEITO GERENCIADO

Os sistemas de IA devem **atenuar preconceitos e discriminações prejudiciais**, o que pode aumentar os níveis de justiça, tendo em conta as diferenças culturais e contextuais.

RESPONSÁVEL e TRANSPARENTE

Os sistemas de IA devem **fornecer níveis adequados de informação**, dependendo do ciclo de vida da IA e adaptados ao ator da IA que interage com ela, **aumentando assim a confiança**

O NIST também publicou o **NIST Generative AI Profile (AI 600-1)**, que serve como complemento ao NIST AI RMF e fornece orientação direcionada para gerenciar riscos associados a sistemas de IA generativa. Além disso, em 2026 o NIST lançou a “**AI Agent Standards Initiative**”, buscando mais confiança, interoperabilidade e segurança para “Agentic AI”

Comparativo: ISO/IEC 42001:2023 vs. NIST AI RMF

Critério	ISO/IEC 42001:2023	NIST AI RMF
Tipo	Norma certificável (auditável por terceiros)	Framework voluntário de referência (não certificável)
Origem	ISO/IEC — internacional	NIST — EUA, adoção global
Estrutura	PDCA (Plan-Do-Check-Act) + Requisitos e Anexos	4 funções: GOVERN · MAP · MEASURE · MANAGE
Foco principal	Sistema de gestão organizacional para IA responsável	Gestão de riscos técnicos e sociais de sistemas de IA
Quem usa	Empresas que querem certificação e demonstrar maturidade	Organizações que precisam de guia prático de risco de IA
Governança	Liderança, política, papéis, responsabilidades explícitas	GOVERN como função central — cultura de risco de IA
Avaliação de Impacto	Avaliação de impacto do sistema de IA (AI-IA) integrada	MAP inclui categorização e análise de impacto
Complemento	ISO 23894 (riscos) · ISO 42005 (impacto)	AI 600-1 (Generative AI) · AI Agent Standards 2026

💡 São **complementares**: muitas organizações adotam ambos. O NIST RMF pode ser usado para cumprir requisitos da ISO 42001.

Regulamentações de IA ao redor do mundo

Diversas jurisdições introduziram novas regulamentações específicas para IA que estão impulsionando a necessidade de governança de IA. Alguns exemplos:

UE	EU AI Act (Reg. 2024/1689) <i>Vigente desde jul 2024</i> Framework horizontal baseado em risco; multas até 7% do faturamento global; cria AI Office europeu	BR PL 2338/2023 (Marco Legal de IA) <i>Aprovado no Senado; tramita na Câmara (2025)</i> Define princípios, direitos, deveres, classificação de risco e futura autoridade supervisora	EUA Executive Order 14110 (Revogada em jan 2025) <i>Revogada pela nova administração</i> Diretrizes de segurança, testes e transparência. Debate continua no Congresso
CO	Colorado AI Act (SB 24-205) <i>Vigente desde fev 2026</i> Primeira lei estadual ampla nos EUA; exige gestão de risco e avaliações de impacto	JP AI Fundamental Law (AI Bill 2025) <i>Aprovado em mai 2025</i> Princípios orientadores, cooperação com investigações e criação do AI Strategy Center	BR+ CFM Res. 2.454/2026 (IA na Medicina) <i>Publicada em 2026</i> Regulamenta uso de IA na prática médica brasileira; exige supervisão humana e responsabilidade do médico

Referências Públicas: https://iapp.org/media/pdf/resource_center/global_ai_law_policy_tracker.pdf
<https://www.techieray.com/GlobalAIRegulationTracker>

PL 2338/2023 — Marco Legal de IA no Brasil (1/3)

O PL 2338/2023 estabelece princípios, direitos e obrigações para o desenvolvimento e uso de sistemas de IA no Brasil. Aprovado no Senado Federal em dez/2024, segue em análise na Câmara dos Deputados (Abril 2026).

Princípios Fundamentais	
1	Transparência e explicabilidade das decisões automatizadas
2	Responsabilidade e prestação de contas dos agentes de IA
3	Não discriminação e proteção de grupos vulneráveis
4	Proteção da privacidade e dados pessoais (alinhado à LGPD)
5	Participação humana em decisões de alto impacto
6	Segurança, confiabilidade e robustez dos sistemas de IA

Direitos dos Usuários e Titulares	
✓	Direito à informação sobre o uso de IA em decisões que o afetem
✓	Direito à explicação de decisões automatizadas de alto risco
✓	Direito à contestação de decisões automatizadas
✓	Direito à revisão humana de decisões de alto impacto
✓	Proteção especial de crianças, adolescentes e vulneráveis
✓	Direito de não ser objeto de vigilância massiva por IA

PL 2338/2023 — Marco Legal de IA no Brasil (2/3)

Classificação de Risco dos Sistemas de IA		Agentes e Obrigações	
Risco Excessivo / Inaceitável	Sistemas de controle social, manipulação de vulneráveis, vigilância biométrica em massa	Fornecedor	Disponibiliza sistema de IA. Responsável pelo design, desenvolvimento e documentação. Deve realizar avaliações de risco e conformidade.
Alto Risco	Saúde, crédito, emprego, educação, segurança pública, infraestrutura crítica, justiça	Operador	Usa o sistema de IA no seu contexto. Deve garantir uso conforme o propósito declarado e implementar controles adicionais se necessário.
Risco Limitado	Chatbots e sistemas de interação que devem se identificar como IA	Usuário	Pessoa natural que interage com o sistema. Tem direitos de informação, explicação, contestação e revisão humana.
Risco Mínimo	Jogos, filtros de conteúdo, recomendações sem impacto significativo	Autoridade Supervisora	Órgão nacional a ser criado para fiscalizar o cumprimento, aplicar sanções e orientar as organizações.

⚠ Para sistemas de ALTO RISCO: avaliação de conformidade obrigatória antes da implantação, registro em cadastro nacional e relatório de impacto algorítmico.

PL 2338/2023 — Marco Legal de IA no Brasil (3/3)

O que muda para organizações que desenvolvem ou usam IA no Brasil:

Documentação e Transparência

Sistemas de IA de alto risco exigirão documentação técnica detalhada, incluindo arquitetura, dados de treinamento, métricas de desempenho e testes de fairness. Model cards se tornam obrigatórios, não apenas boas práticas.

Avaliação de Impacto Algorítmico (AIA)

Obrigações de conduzir AIAs antes da implantação de sistemas de alto risco. Análise de impactos discriminatórios, de privacidade e sobre grupos vulneráveis.

Revisão Humana (Human-in-the-Loop)

Decisões automatizadas de alto impacto em saúde, crédito, emprego e justiça devem ter mecanismo real de revisão e contestação por humano habilitado.

Responsabilidade Civil e Sanções

Inversão do ônus da prova: o fornecedor/operador deve provar que o sistema operou corretamente. Multas proporcionais ao porte e ao impacto do dano.

Integração com LGPD

IA que processa dados pessoais opera sob a LGPD em paralelo. O PL reforça obrigações já existentes e cria proteções específicas para decisões automatizadas.

Autoridade Nacional de IA

Prevê criação de órgão regulador (ex.: vinculado à ANPD ou autarquia própria) com poderes de fiscalização, sanção e orientação setorial.

LGPD (Lei 13.709/2018) — Conceitos Fundamentais

A Lei Geral de Proteção de Dados (LGPD) regula o tratamento de dados pessoais por pessoas naturais ou jurídicas, de direito público ou privado, no Brasil, em vigor desde Set/2020 com sanções desde Ago/2021.

Dado Pessoal	Qualquer informação que identifique ou torne identificável uma pessoa natural: nome, CPF, e-mail, localização, IP, cookie, biometria etc.	Dado Sensível	Dado pessoal com proteção reforçada: origem racial/étnica, convicção religiosa, opinião política, dado de saúde, vida sexual, dado genético ou biométrico.
Titular	Pessoa natural a quem os dados se referem. Possui direitos: acesso, correção, portabilidade, anonimização, eliminação e oposição.	Controlador	Quem decide sobre o tratamento dos dados (ex.: a empresa que desenvolve ou opera o sistema de IA). Responde perante o titular e a ANPD.
Operador	Quem realiza o tratamento em nome do controlador (ex.: fornecedor de infraestrutura de nuvem ou API de IA). Também tem obrigações legais.	DPO / ANPD	DPO (Encarregado): canal entre controlador, titulares e ANPD. ANPD: Autoridade Nacional de Proteção de Dados fiscaliza e aplica sanções de até R\$ 50 mi ou 2% do faturamento.

10 Bases Legais de Tratamento (Art. 7º): Consentimento · Obrigação legal · Contrato · Tutela da saúde · Interesse legítimo · Proteção do crédito (+ 4 outras)

LGPD e Inteligência Artificial — Implicações e Riscos

A LGPD não menciona IA explicitamente, mas seus requisitos impactam diretamente todo o ciclo de vida de sistemas de IA que processam dados pessoais.

Decisões Automatizadas

Art. 20

O titular tem direito a solicitar revisão humana de decisões tomadas unicamente por tratamento automatizado. Modelos de crédito, contratação e diagnóstico devem ter mecanismo real de revisão por pessoa qualificada.

Finalidade e Minimização

Art. 6

Dados só podem ser usados para o propósito declarado na coleta. Usar dados de atendimento para treinar um modelo de IA requer nova base legal ou consentimento. Colete apenas o necessário.

Dados Sensíveis em IA

Art. 11

Dados de saúde, biometria, raça/etnia exigem consentimento específico e destacado. Modelos treinados com esses dados (reconhecimento facial, diagnóstico médico) têm obrigações adicionais.

Direito ao Esquecimento

Art. 18

Dados eliminados podem persistir no modelo como 'memórias'. Machine Unlearning é hoje um desafio técnico-legal: o modelo pode ter memorizado PII que precisa ser desaprendida.

RIPD Obrigatorio

Art. 37

Sistemas de IA que tratam dados sensíveis ou em larga escala exigem "Relatório de Impacto a Proteção de Dados (RIPD)". Deve descrever dados, metodologia, riscos e medidas de mitigação.

Segurança Técnica

Art. 46

Modelos LLM podem vaziar dados de treino via outputs. Risco de memorização deve ser mitigado com differential privacy, guardrails e testes de extração antes do deploy.

LGPD na Prática: IA e Agentes de IA Autônomos

Checklist LGPD para Sistemas de IA

- ✓ Mapeie todos os dados pessoais no pipeline (coleta, treino, inferência, logs)
- ✓ Defina a base legal para cada finalidade antes de iniciar o projeto
- ✓ Implemente minimização: use apenas os atributos necessários; anonimize o restante
- ✓ Implemente revisão humana para decisões automatizadas de alto impacto (Art. 20)
- ✓ Documente um RIPD se tratar dados sensíveis ou em larga escala
- ✓ Crie mecanismo de atendimento a direitos dos titulares (acesso, correção, eliminação)
- ✓ Proteja contra memorização de PII no modelo (ex.: differential privacy, data masking)
- ✓ Registre logs de tratamento por decisão automatizada para rastreabilidade

Princípio-chave: Privacy by Design (Art. 46, par.2), proteção de dados deve ser considerada desde a concepção da arquitetura, não como add-on pós-deploy.

Agentes de IA Autônomos: Riscos Específicos

Coleta invisível de PII

Agentes que navegam na web, lêem e-mails ou acessam sistemas podem coletar dados pessoais sem base legal clara; cada ação autônoma pode ser um 'tratamento' sob a LGPD.

Cadeia de controladores/operadores

Em arquiteturas multi-agente (orquestrador + subagentes + ferramentas externas), a responsabilidade pelo tratamento de dados se fragmenta. Quem é o controlador? Quem é o operador?

Transferência internacional de dados

Agentes que usam APIs de LLMs estrangeiros (OpenAI, Anthropic, Google) transferem dados pessoais para fora do Brasil, exige cláusulas contratuais ou verificação de adequação (Art. 33).

Ausência de human-in-the-loop

Agentes totalmente autônomos que tomam decisões sobre pessoas sem supervisão humana conflitam com o Art. 20. Arquiteturas agentic AI devem incluir pontos de controle e aprovação humana.

Resolução CFM no. 2454/2026 – IA na Medicina

IA na Medicina: O Novo Marco Regulatório (Resolução CFM nº 2.454/2026)

O Conselho Federal de Medicina estabeleceu a primeira norma específica para IA na prática médica no Brasil. A resolução define que a tecnologia deve atuar estritamente como suporte, preservando a autonomia do médico e a segurança do paciente acima de qualquer automação.

PRINCÍPIOS ÉTICOS E DIREITOS



IA como Apoio, Nunca Substituição

O médico detém a responsabilidade final por diagnósticos e condutas terapêuticas.



Direito de Informação e Recusa

Pacientes devem ser informados sobre o uso de IA e podem recusar a tecnologia.



Autonomia Médica Protegida

O profissional tem o direito de ignorar ou adaptar recomendações geradas por algoritmos.



GOVERNANÇA E CONFORMIDADE



Fim dos Sistemas "Caixa-Preta"

Soluções devem ser auditáveis, rastreáveis e oferecer explicações claras sobre seus resultados.



Prazo de 180 Dias para Adequação

Empresas e hospitais têm seis meses para ajustar processos técnicos e contratuais.



Responsabilidade Técnica Centralizada

O Diretor Técnico de instituição responde formalmente pela fiscalização do uso da IA.

NOVA MATRIZ DE CLASSIFICAÇÃO DE RISCO



Baixo / Médio

Impacto clínico reduzido e baixa autonomia.

Uso permitido com monitoramento.



Alto

Grande impacto em direitos fundamentais ou gravidade clínica.

Exige validação científica e controles rigorosos.



Inaceitável

Sistemas que violam a ética ou autonomia humana.

Uso proibido na prática médica brasileira.

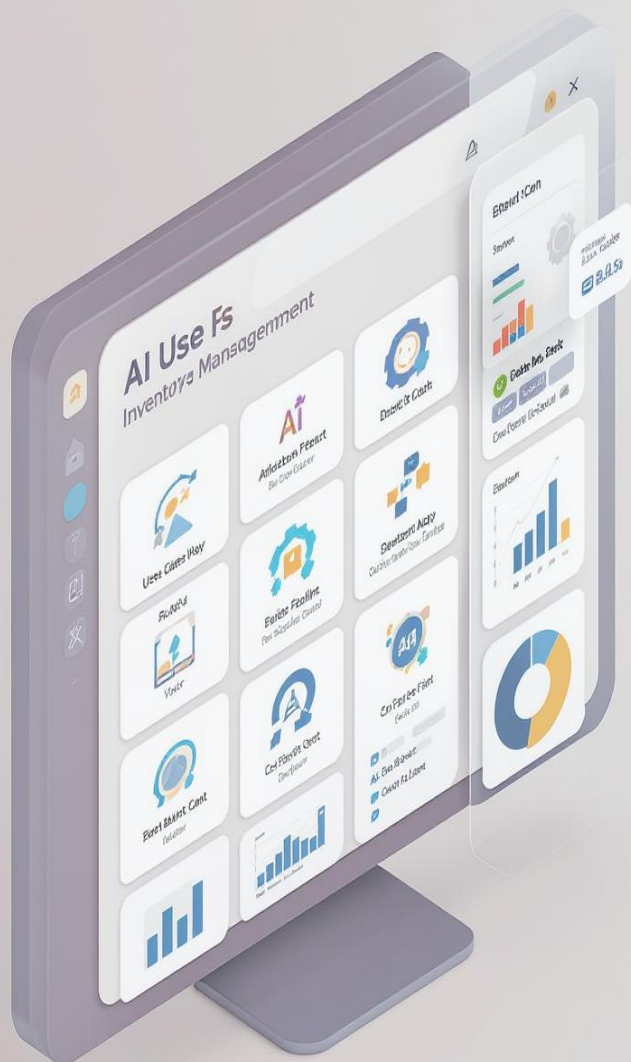


04

Gestão de Valor da IA

Do inventário de casos de uso ao ROI real

Inventário de Casos de Uso de IA



Ponto de partida para governança estruturada de IA

Visibilidade do Portfólio

"Mapa" de todos os modelos em uso: onde, como e para quê. Facilita descobrir redundâncias e lacunas estratégicas.

Classificação de Riscos

Com todos os casos listados, aplica-se a matriz probabilidade × impacto para determinar quais exigem avaliações mais profundas (ex.: alto risco pelo EU AI Act).

Alinhamento Estratégico

Verifica se cada iniciativa de IA suporta objetivos corporativos, evitando projetos que consomem recursos sem retorno claro.

Base para Auditoria

ISO 42001, NIST AI RMF e reguladores pedem rastreabilidade. O inventário cria trilhas auditáveis para inspeções internas ou externas.

Reutilização de Ativos

Equipes vêm modelos existentes e reaproveitam componentes em vez de reconstruir, reduz time-to-market e custo.

Desenvolver “Business Cases” de IA

Cada caso de uso de IA deve ter um business case que justifique o investimento e permita acompanhar o valor entregue. Exemplos:

Redução de Custos		Aumento de Receita	
• Geração de código (dev)	Redução de 30-40% no tempo de desenvolvimento (GitHub Copilot/McKinsey, 2024)	• Personalização de ofertas (marketing)	Aumento de 15-25% em taxa de conversão (McKinsey Global Institute)
• Automação de análise de contratos (jurídico)	Redução de até 85% no tempo de análise documental (Accenture)	• Gestão de patrimônio c/ IA	Aumento de produtividade de consultores financeiros em 20-30%
• Combate à lavagem de dinheiro	Redução de 20-30% em falsos positivos = menor custo de investigação	• Precificação dinâmica	Melhora de 5-10% em margem bruta em varejo e e-commerce
Mitigação de Riscos		Satisfação do Cliente	
• Detecção de fraude em cartão	Redução de 40-60% em perdas com fraude (caso Nubank/Mercado Pago)	• Chatbot de atendimento 24/7	Redução de 60% no tempo de espera (Gartner 2024)
• Monitoramento de compliance regulatório	Redução de multas e retrabalho de auditoria	• Recomendação personalizada	Aumento de NPS e retenção em plataformas de streaming (Netflix: +25%)
• Análise preditiva de crédito	Redução de 15-20% na taxa de inadimplência	• Diagnóstico médico assistido por IA	Redução de tempo p/ diagnóstico; melhora de outcomes clínicos

FinOps para IA: Gestão de Custos e Otimização

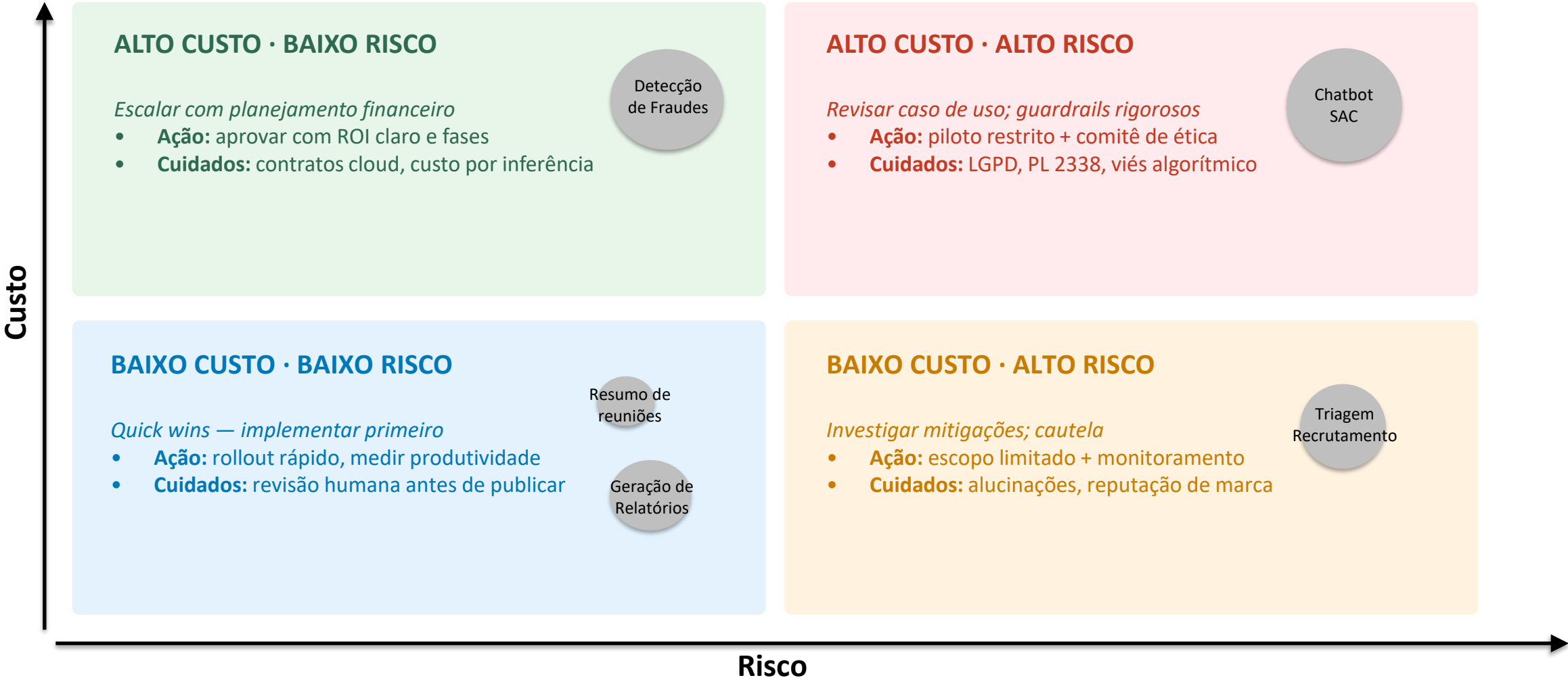
A **precificação de IA é bastante complexa** e varia conforme cada fornecedor. A disciplina de FinOps, que nasceu com “Cloud”, precisa se expandir para cobrir gastos com IA.

1 – Modelo SaaS (ex.: ChatGPT Enterprise)	Faturamento por tokens (input/output); variação por modalidade (texto, imagem, áudio); copilots de fornecedores SaaS (ex.: Salesforce Einstein, M365 Copilot)
2 – API de Modelo Fechado (ex.: OpenAI, Anthropic)	Tokens input × output × modelo (GPT-4o vs. GPT-4 mini); custo por chamada; variação de preço por versão e capacidade de contexto
3 – Modelo Open Source no-state (ex.: Llama, Mistral)	Custo de compute (GPU/TPU); eletricidade e manutenção se on-premise; aluguel de GPU na nuvem; custos de integração e orquestração
4 – Fine-tuning / ReTreinamento	Recursos computacionais intensos; armazenamento de dados de treino; tempo de engenheiros especializados; ciclos de validação e QA do modelo ajustado

💡 Práticas de FinOps para IA: rastrear custo por caso de uso; usar modelos menores onde suficiente; cachear respostas repetidas; monitorar token consumption por área/time.

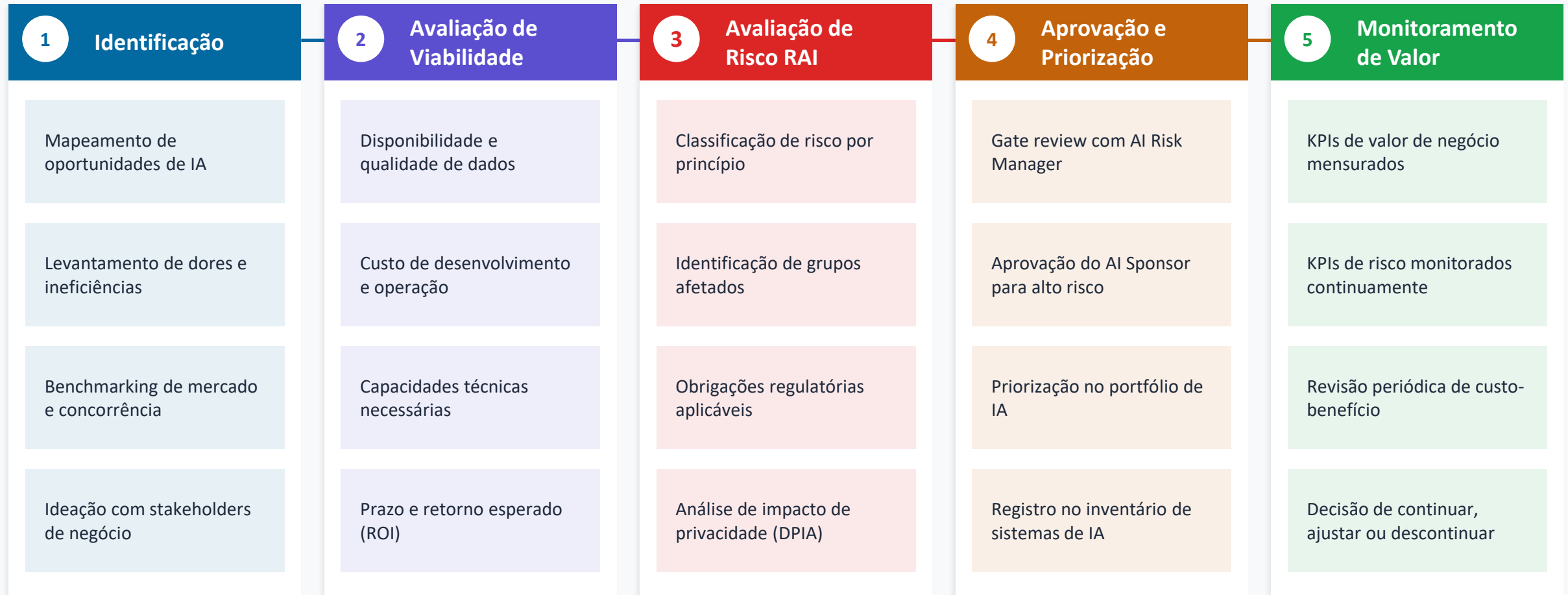
Priorização: Valor × Custo × Risco

Tamanho = Valor a ser gerado
Obs.: Exemplos ilustrativos



Gestão de Casos de Uso e Valor de IA

Nem todo caso de uso de IA deve ser construído. A governança começa com a decisão de usar, e inclui avaliar risco, viabilidade e valor antes de qualquer linha de código.



Alfabetização em IA (AI Literacy)

Podemos definir AI Literacy como o conjunto de competências que permite avaliar criticamente tecnologias de IA, colaborar com sistemas de IA e utilizá-los com efetividade e responsabilidade.

Todos na Empresa

Objetivos: Uso seguro e responsável de ferramentas de IA no trabalho

Ex.: Vídeo de 30 min · E-learning sobre uso do MS Copilot · Políticas de uso aceitável de IA Generativa

Conselho e Alta Liderança

Objetivos: Estratégia, riscos e governança de IA; casos de uso no setor

Ex.: Workshops com especialistas · Sessões de educação executiva · Guia IA para Conselheiros (Accenture/IBGC)

Gestores e Líderes Técnicos

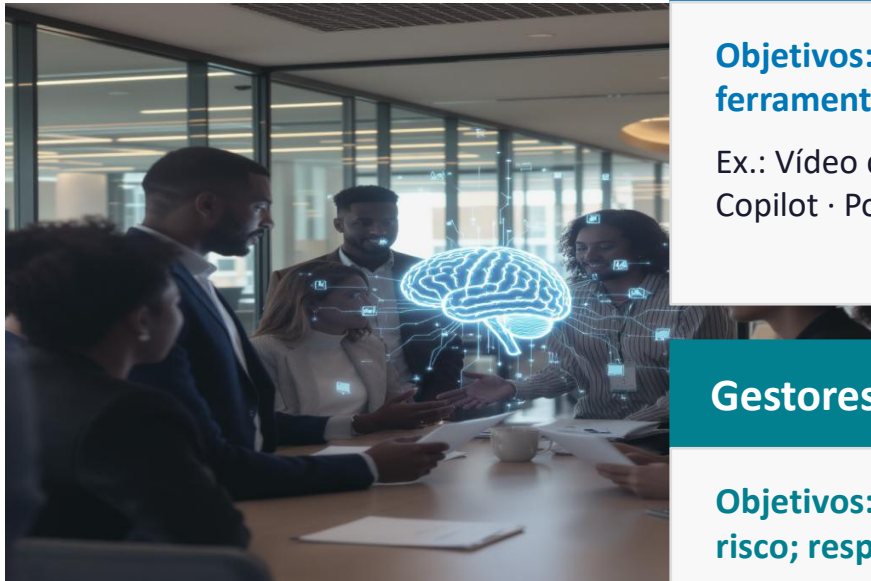
Objetivos: Gestão de projetos de IA; avaliação de risco; responsabilidade

Ex.: Cursos de Responsible AI (Stanford HAI, Google, Coursera) · Certificações ISO 42001 · Simulações de tomada de decisão

Desenvolvedores e Cientistas de Dados

Objetivos: Técnicas avançadas de IA; fairness; MLOps; segurança de IA

Ex.: Treinamentos especializados (Coursera, Udemy, Fast.ai) · Certificações cloud (AWS, Azure, GCP) · Hackathons internos



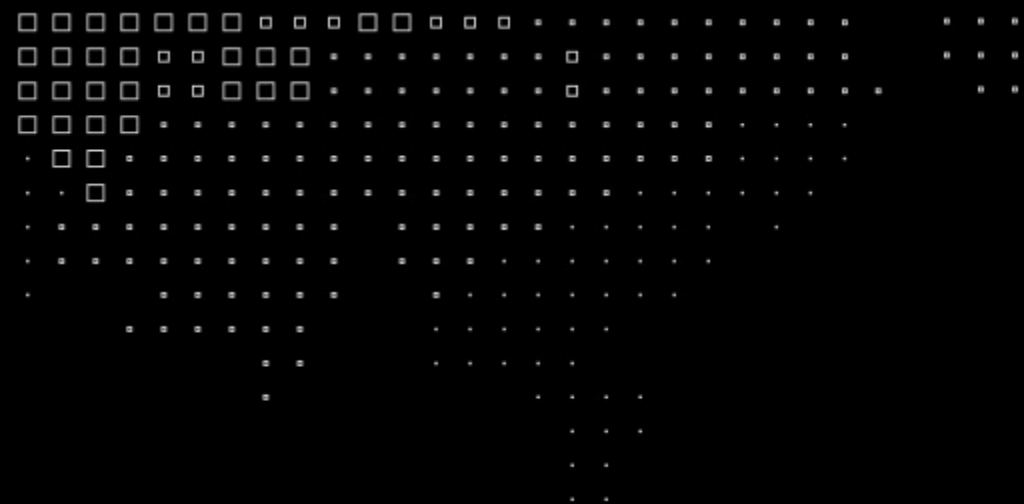
Modelo de Maturidade em IA Responsável

Como evoluir a maturidade da sua organização em Responsible AI (exemplo):

1 – Inicial	Sem políticas formais. IA usada ad hoc por equipes técnicas. Sem inventário de modelos. Riscos não mapeados.
2 – Consciente	Primeiras políticas de uso de IA. Inventário inicial de casos de uso. Governança informal — alguns papéis definidos.
3 – Definido	Políticas e processos documentados. CoE de IA ativo. Avaliações de risco em projetos de alto impacto. AI Literacy em curso.
4 – Gerenciado	Métricas de fairness e bias monitoradas em produção. Registro de modelos completo. Alinhamento com ISO 42001 ou NIST RMF.
5 – Otimizado	Cultura de IA responsável enraizada. Certificação ISO 42001. Reporte ESG de IA. Inovação responsável como diferencial competitivo.

💡 Ref: CMMI AI · Accenture AI Maturity Index · BCG Responsible AI Maturity Model — a maioria das empresas está entre os níveis 1 e 2.

FINAL DA PARTE 3

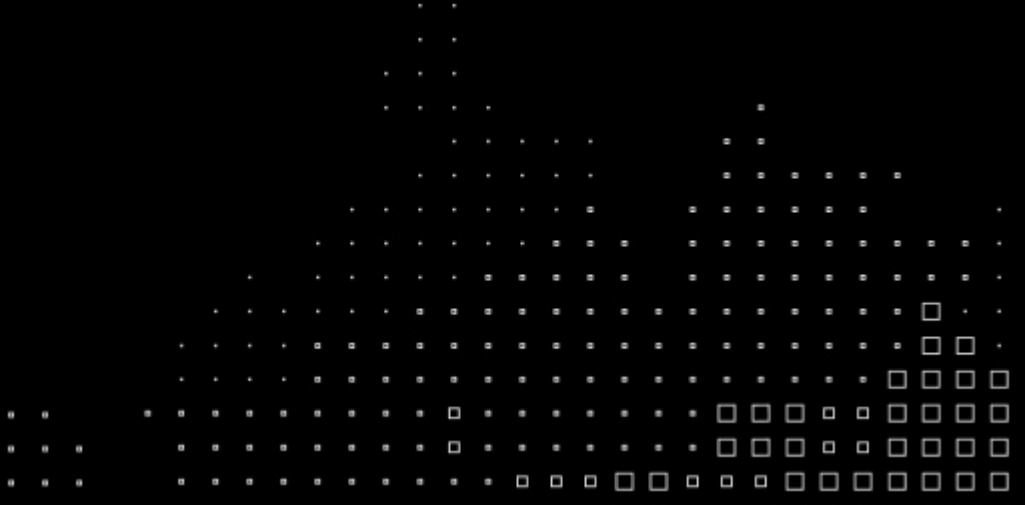


MBA⁺

Copyright © **2026** Professor:

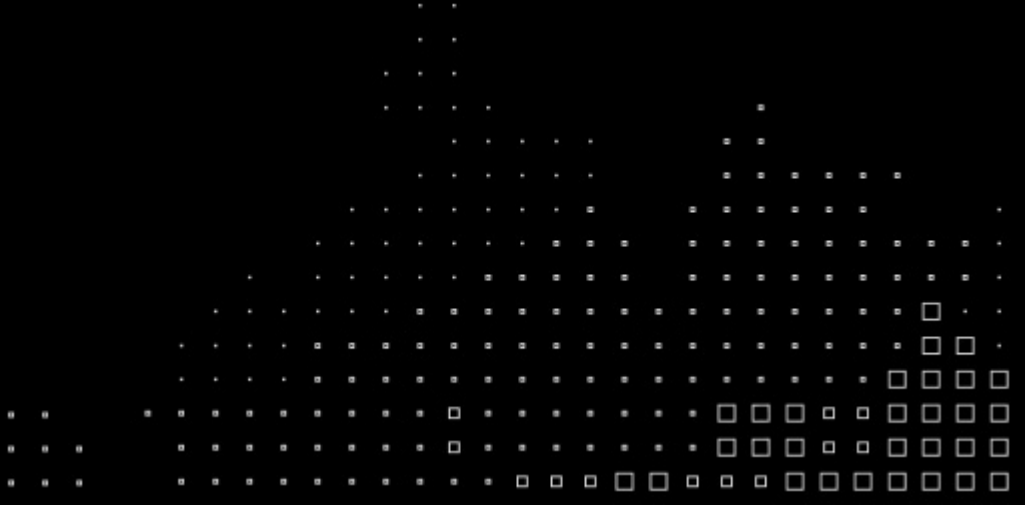
- Sergio Alexandre Naime Mantovani

Todos direitos reservados. Reprodução ou divulgação total ou parcial deste documento é expressamente proibida sem o consentimento formal, por escrito, dos Professores (autores).

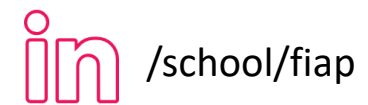


MBA⁺

**MBA DATA SCIENCE &
ARTIFICIAL INTELLIGENCE**



OBRIGADO



FIAP MBA⁺